

Non-Functional Requirements Document

TrustLot Used Car Marketplace Platform

Version: 1.0

Date: June 10, 2026

Project: TrustLot - Full-Stack Used Car Buy-and-Sell Marketplace

Document Type: Non-Functional Requirements Specification

Table of Contents

1. Introduction
 2. Performance Requirements
 3. Reliability Requirements
 4. Security Requirements
 5. Usability Requirements
 6. Maintainability Requirements
 7. Scalability Requirements
 8. Data Integrity Requirements
 9. Portability Requirements
 10. Audit and Logging Requirements
 11. Constraints
 12. Future Non-Functional Requirements
 13. Conclusion
-

1. Introduction

1.1 Purpose

This Non-Functional Requirements (NFR) document specifies the quality attributes, performance benchmarks, security standards, and operational constraints for the TrustLot used car marketplace platform. It complements the functional requirements by defining how the system should behave in terms of performance, reliability, security, and other quality characteristics essential for enterprise-grade operations.

1.2 Scope

This document applies to all components of the TrustLot platform including: - **Backend Services:** Spring Boot REST API, business logic, and data management - **Frontend Application:** Angular-based web interface for buyers, sellers, and administrators - **Database:** Apache Derby (development) and MySQL (production) - **Infrastructure:** Cloud-based deployment and monitoring systems - **Third-party Integrations:** Payment gateways, email services, and analytics platforms

1.3 Audience

This document is intended for: - Development and QA teams - System architects and DevOps engineers - Project managers and stakeholders - Operations and support teams - Security auditors and compliance officers

2. Performance Requirements

2.1 Response Time Requirements

Operation	Target Response Time	Acceptable Range
User Login/Authentication	500 ms	400-700 ms
Browse Available Cars	1 second	800 ms - 1.5 sec
Car Detail View (with reviews)	800 ms	600 ms - 1.2 sec
Compare Two Cars	1 second	800 ms - 1.5 sec
Search/Filter Cars	1.2 seconds	1 - 1.5 sec
Purchase Initiation	2 seconds	1.5 - 3 sec
Admin Dashboard Load	1.5 seconds	1 - 2 sec
Receipt Generation/Download	3 seconds	2 - 4 sec
Support Ticket Creation	1 second	800 ms - 1.5 sec

Measurement: Response time measured from client request submission to complete response delivery, excluding network latency beyond the application tier.

2.2 Database Operation Performance

- **Query Response Time:** All database queries must complete within 500 ms under normal load
- **Bulk Operations:** Batch insert/update operations (Admin operations) must complete within 5 seconds for up to 1000 records
- **Transaction Completion:** Purchase transactions must complete within 2 seconds from payment approval to order confirmation
- **Report Generation:** Admin analytics reports must render within 3 seconds for 30-day data sets
- **Concurrent Query Support:** Database must handle minimum 100 concurrent SELECT queries without performance degradation

2.3 Purchase Process Performance

- **Payment Processing:** Payment gateway integration must respond within 5 seconds
- **Order Creation:** Order creation and storage must complete within 2 seconds
- **Email Notification:** Automated email notifications must be sent within 30 seconds of order state change
- **Receipt Generation:** PDF receipt generation must complete within 3 seconds of request
- **Fraud Detection:** Fraud check algorithm must execute within 500 ms of purchase submission

2.4 Bill/Receipt Generation

- **Receipt Format:** PDF generation with all required fields (buyer, seller, car, payment, order details)
- **Generation Time:** Receipt must be generated and available for download within 3 seconds
- **File Size:** PDF file size must not exceed 2 MB
- **Accuracy:** All numerical values (price, tax, total) must be calculated with precision to 2 decimal places
- **Availability:** Generated receipts must be retrievable from archive for minimum 7 years

3. Reliability Requirements

3.1 System Availability

- **Target Uptime:** 99.5% availability annually (maximum 43.8 hours downtime per year)
- **Peak Hours Availability:** 99.9% during business hours (9 AM - 6 PM IST, Monday-Friday)
- **Maintenance Window:** Maximum 4 hours per month for scheduled maintenance
- **Planned Downtime:** Must be scheduled during off-peak hours with 72-hour advance notice

3.2 Error Handling and Recovery

- **Graceful Degradation:** System must degrade gracefully; non-critical features may be disabled but core transactions must continue
- **Error Recovery:** System must automatically recover from transient database connection failures within 30 seconds
- **Payment Failure Handling:** Failed payments must automatically rollback related orders and free up car availability
- **Session Timeout Recovery:** Expired sessions must prompt user to re-authenticate without losing unsaved data
- **Error Logging:** All errors must be logged with full context for post-incident analysis

3.3 Fault Tolerance

- **Database Failover:** Automatic failover to standby database within 60 seconds upon primary database failure
- **Service Redundancy:** Critical services (Auth, Purchase, Payment) must run in active-passive configuration
- **Network Resilience:** System must handle temporary network interruptions (up to 30 seconds) and retry failed requests
- **Cache Fallback:** Upon cache failure, system must seamlessly fall back to direct database queries
- **Load Balancer:** Health checks must monitor backend instances every 30 seconds and remove unhealthy instances

3.4 Data Backup and Recovery

- **Backup Frequency:** Full database backup daily at 2 AM UTC; incremental backups every 6 hours
 - **Backup Retention:** Retain daily backups for 30 days; monthly backups for 12 months
 - **Recovery Time Objective (RTO):** System must recover from complete data loss within 4 hours
 - **Recovery Point Objective (RPO):** Maximum 1 hour of data loss acceptable
 - **Backup Testing:** Backup restoration must be tested monthly to verify integrity
-

4. Security Requirements

4.1 Authentication and Authorization

- **Password Policy:** Minimum 10 characters with mixed alphanumeric and special characters
- **Session Management:** Custom session tokens with 120-minute expiration
- **Session Invalidation:** Immediate session termination on logout and password change
- **Concurrent Sessions:** Users may have maximum 3 concurrent active sessions
- **Role-Based Access Control:** Only ADMIN role can approve cars and orders; only sellers can approve sales
- **Authorization Enforcement:** All protected endpoints must validate user role before processing

4.2 Data Protection

- **Encryption in Transit:** All API communications must use HTTPS/TLS 1.2 or higher
- **Encryption at Rest:** Sensitive data (passwords, payment info) must be encrypted using AES-256
- **Password Hashing:** Passwords must be hashed using bcrypt with minimum salt rounds of 10
- **PCI Compliance:** Payment information must comply with PCI-DSS standards
- **Data Masking:** Credit card numbers, phone numbers masked in logs and error messages

4.3 Vulnerability Management

- **OWASP Top 10 Prevention:** System must be protected against SQL injection, XSS, CSRF, and other OWASP vulnerabilities
- **Input Validation:** All user inputs must be validated and sanitized before processing
- **SQL Injection Protection:** Parameterized queries must be used for all database operations
- **XSS Protection:** Output encoding must be applied to all user-generated content
- **Security Testing:** Quarterly penetration testing and vulnerability assessments required

4.4 Fraud Detection and Prevention

- **Purchase Fraud Monitoring:** Flag accounts with >3 approved purchases for manual review
- **Payment Validation:** Cross-check payment information against known fraud patterns
- **Rate Limiting:** API endpoints must enforce rate limiting (max 100 requests/minute per user)
- **Anomaly Detection:** Monitor for unusual access patterns and flag for investigation
- **IP Whitelisting:** Admin operations restricted to configured IP ranges in production

4.5 Compliance and Privacy

- **Data Privacy:** User data must be handled per privacy policy and applicable regulations
 - **GDPR Compliance:** User data deletion and export capabilities must be provided
 - **Data Retention:** User data retention policies must be defined and enforced
 - **Terms of Service:** All users must accept terms before account creation
 - **Audit Trail:** All administrative actions must be logged with timestamp and user identification
-

5. Usability Requirements

5.1 User Interface Design

- **Responsive Design:** Web interface must be fully functional on desktop (1920x1080), tablet (768x1024), and mobile (375x667) resolutions
- **Load Time:** Initial page load must complete within 3 seconds on 4G connection
- **Navigation:** Core features (Browse, Purchase, Dashboard) must be accessible within 2 clicks
- **Accessibility:** WCAG 2.1 Level AA compliance for accessibility standards
- **Browser Support:** Support for Chrome 90+, Firefox 88+, Safari 14+, Edge 90+

5.2 User Experience

- **Onboarding:** New users must complete registration and first purchase within 5 minutes
- **Dashboard Clarity:** Admin and user dashboards must display key metrics at a glance
- **Error Messages:** All error messages must be clear, actionable, and suggest remediation steps
- **Confirmation Dialogs:** Critical actions (purchase, delete listing) must require explicit confirmation
- **Undo/Cancel:** Users must be able to cancel incomplete transactions without losing data

5.3 Accessibility

- **Keyboard Navigation:** All features must be accessible via keyboard without mouse
- **Screen Reader Support:** Critical content must be properly labeled for screen readers
- **Color Contrast:** Text contrast ratio must meet WCAG AA standards (4.5:1 for body text)
- **Font Size:** Minimum readable font size 12px; user must be able to increase up to 200%
- **Form Labels:** All form inputs must have associated labels for accessibility

5.4 Help and Documentation

- **In-App Help:** Contextual help tooltips for complex features

- **FAQ Section:** Comprehensive FAQ covering common user queries
 - **Video Tutorials:** Step-by-step video guides for key workflows
 - **Contact Support:** Support ticket system easily accessible from all pages
 - **Knowledge Base:** Searchable knowledge base with common issues and solutions
-

6. Maintainability Requirements

6.1 Code Quality

- **Code Standards:** Follow Google Java Style Guide and Angular Style Guide
- **Code Coverage:** Minimum 80% unit test coverage for critical modules
- **Code Review:** All code changes must undergo peer review before merge
- **Documentation:** All public APIs must be documented with JavaDoc/TSDoc
- **Naming Conventions:** Clear, meaningful variable and function names following industry standards

6.2 System Monitoring and Observability

- **Application Logging:** Structured logging (JSON format) for all significant events
- **Log Levels:** DEBUG, INFO, WARN, ERROR appropriately applied
- **Performance Metrics:** Monitor CPU, memory, disk, network usage; alert on anomalies
- **Application Metrics:** Track API response times, error rates, request volumes
- **Health Checks:** Automated health check endpoints for all microservices

6.3 Documentation

- **API Documentation:** OpenAPI/Swagger documentation for all REST endpoints
- **Architecture Documentation:** System design, data flow, and deployment diagrams
- **Deployment Guides:** Step-by-step instructions for deploying to various environments
- **Configuration Documentation:** All environment variables and configuration options documented
- **Troubleshooting Guide:** Common issues and resolution steps documented

6.4 Backward Compatibility

- **API Versioning:** Support for multiple API versions during transition periods
 - **Database Migration:** Automated scripts for schema changes with rollback capability
 - **Dependency Management:** Regular security updates while maintaining compatibility
 - **Breaking Changes:** Major breaking changes announced with minimum 2-week deprecation period
 - **Legacy Support:** Support for deprecated endpoints for minimum 6 months
-

7. Scalability Requirements

7.1 Horizontal Scalability

- **Stateless Services:** Backend services must be stateless to enable horizontal scaling
- **Load Balancing:** Load balancer must distribute traffic evenly across instances
- **Auto-Scaling:** Kubernetes or similar orchestration for automatic scaling based on CPU/memory
- **Session Sharing:** Session data stored in Redis for sharing across instances
- **Concurrent Users:** System must support minimum 10,000 concurrent users without degradation

7.2 Database Scalability

- **Connection Pooling:** Database connection pool minimum 20, maximum 100 connections
- **Query Optimization:** All queries must have execution plans reviewed and optimized

- **Indexing Strategy:** Strategic indexing on frequently queried columns
- **Partitioning:** Large tables (Cars, Orders) partitioned by date range
- **Read Replicas:** Separate read replicas for analytics and reporting queries

7.3 Storage Scalability

- **Storage Capacity:** Design for 100 GB data growth per month
- **File Storage:** External storage (S3/Cloud Storage) for car images and documents
- **Archive Strategy:** Automated archiving of data older than 2 years
- **Compression:** Compress archived data to reduce storage costs
- **Data Lifecycle:** Clear data retention and purging policies

7.4 Performance Under Load

- **Peak Load Handling:** System must handle 2x normal load with <10% performance degradation
- **Stress Testing:** Regular stress testing with simulated peak loads
- **Capacity Planning:** Quarterly capacity reviews and forecasting
- **Resource Limits:** Set resource quotas per tenant/user to prevent resource exhaustion
- **Graceful Degradation:** Non-critical features (analytics) may be disabled under extreme load

8. Data Integrity Requirements

8.1 Transaction Management

- **ACID Compliance:** All transactions must maintain ACID properties (Atomicity, Consistency, Isolation, Durability)
- **Transaction Isolation:** Minimum READ_COMMITTED isolation level; SERIALIZABLE for critical transactions
- **Deadlock Prevention:** Application must handle and retry on deadlock conditions
- **Distributed Transactions:** Two-phase commit for transactions spanning multiple databases
- **Rollback Capability:** Automatic rollback on transaction failure with no partial updates

8.2 Data Consistency

- **Referential Integrity:** Foreign key constraints enforced at database level
- **Uniqueness Constraints:** Unique constraints on username, email, phone number
- **Data Validation:** Business rule validation at both database and application layers
- **Duplicate Prevention:** Prevent duplicate orders, listings, and reviews through constraints
- **Eventual Consistency:** Cache updates must be eventually consistent with database within 5 minutes

8.3 Concurrency Control

- **Optimistic Locking:** Use version fields to detect concurrent modifications
- **Pessimistic Locking:** Database-level locks for critical operations (purchase, approval)
- **Race Condition Prevention:** Critical sections protected by database-level constraints
- **Concurrent Update Handling:** Last-write-wins strategy with conflict detection
- **Conflict Resolution:** Clear policies for resolving concurrent modifications

8.4 Data Validation Rules

- **Email Format:** Validate against RFC 5322 standard
- **Phone Numbers:** Indian 10-digit format starting with 6-9
- **Car Details:** Year range 1900-2100, price >0, mileage 0
- **Payment Amounts:** Must match car listing price to 2 decimal places
- **Review Ratings:** 1-5 scale enforced, comments 1000 characters

9. Portability Requirements

9.1 Platform Independence

- **Operating System:** Support Windows, Linux (Ubuntu 20.04+, CentOS 8+), and macOS 10.15+
- **Java Version:** Compatible with Java 17 and future LTS versions
- **Database Portability:** Support for both Apache Derby and MySQL; easily switch between them
- **Browser Compatibility:** Frontend works on all major browsers (Chrome, Firefox, Safari, Edge)
- **Cloud Agnostic:** Infrastructure-agnostic code; deployable on AWS, Azure, GCP, or on-premise

9.2 Framework and Library Portability

- **Spring Boot:** Use stable versions; avoid deprecated features
- **Angular:** Use stable Angular versions; follow framework update path
- **Database Drivers:** Use standard JDBC drivers; no database-specific code
- **Build System:** Maven build files must be reproducible across environments
- **Dependency Management:** All external dependencies must be explicitly declared with versions

9.3 API Standards Compliance

- **REST Principles:** Follow REST architectural principles for all endpoints
- **HTTP Methods:** Proper use of GET, POST, PUT, DELETE, PATCH
- **Status Codes:** Standard HTTP status codes (200, 201, 400, 401, 403, 404, 500)
- **Content Types:** Support for JSON; consider XML for future compatibility
- **API Versioning:** Version APIs using URL path (e.g., /api/v1/, /api/v2/)

9.4 Data Export and Migration

- **Data Format:** Support CSV and JSON exports for user data
- **Migration Tools:** Automated scripts for database schema migration
- **Batch Export:** Bulk export capability for large data sets
- **Import Utilities:** Tools to import legacy data from other systems
- **Format Standards:** Use standard formats (CSV, JSON, XML) for data interchange

10. Audit and Logging Requirements

10.1 Audit Trail

- **User Actions:** Log all user actions (login, car listing, purchase, review submission)
- **Admin Actions:** Log all administrative actions with details and justification
- **Data Changes:** Track all data modifications with before/after values
- **Timestamp:** All audit entries must include precise timestamp (millisecond precision)
- **Audit Retention:** Retain audit logs for minimum 7 years

10.2 Event Logging

- **Login Events:** Log successful and failed login attempts with IP address
- **Purchase Events:** Log all purchase milestones (initiated, payment processed, approved)
- **Approval Events:** Log listing and order approvals with approval reason/comments
- **System Events:** Log system startup, shutdown, errors, and warnings
- **Security Events:** Log unauthorized access attempts, permission denials, password changes

10.3 Error and Exception Logging

- **Exception Details:** Log full stack trace for all exceptions
- **Context Information:** Include user ID, session ID, request parameters in error logs
- **Error Classification:** Categorize errors (validation, system, integration, database)
- **Error Alerting:** Automatic alerts for critical errors to operations team
- **Log Aggregation:** Centralized log collection and analysis using ELK or similar

10.4 Performance and Access Logging

- **API Access Logs:** Log all API requests (method, endpoint, status code, response time)
 - **Query Performance:** Log slow database queries (>500ms) with execution plan
 - **Resource Usage:** Log high resource consumption (CPU >80%, memory >85%)
 - **Unusual Access:** Log access patterns that deviate from normal (e.g., high request rate)
 - **Log Rotation:** Daily rotation of log files; compress and archive older logs
-

11. Constraints

11.1 Technical Constraints

- **Technology Stack:** Spring Boot 3.3.5, Java 17, Angular 14+, MySQL 8.0+
- **Database:** Apache Derby for development; MySQL for production
- **Deployment:** Docker containerization; Kubernetes orchestration
- **API Framework:** REST-based JSON API; OpenAPI documentation required
- **Session Management:** Server-side session tokens; no JWT initially

11.2 Operational Constraints

- **Business Hours:** Platform operates 24/7; critical maintenance windows only on Sundays 2-4 AM IST
- **Admin Approval:** Listings and orders require manual admin approval; no auto-approval
- **Payment Limit:** Transactions limited to INR 50 lakh per transaction
- **User Limit:** Maximum 3 concurrent sessions per user account
- **Data Residency:** All data must reside within Indian data centers per data localization laws

11.3 Legal and Compliance Constraints

- **Privacy Compliance:** Must comply with GDPR for European users and India Privacy laws
- **Payment Compliance:** Must comply with PCI-DSS for handling payment information
- **Terms of Service:** All users must accept platform terms before account creation
- **Content Moderation:** Car listings and reviews subject to content policy enforcement
- **Tax Compliance:** System must capture and report tax-relevant transaction data

11.4 Resource Constraints

- **Development Team:** 8-10 engineers; architecture must accommodate team size
 - **Budget:** Infrastructure costs must be optimized; no premium services unless justified
 - **Timeline:** Critical features must be delivered within 3-month phases
 - **Third-party Dependencies:** Limit external integrations to essential services only
 - **Support Staff:** Dedicated support team with maximum 24-hour resolution SLA
-

12. Future Non-Functional Requirements

12.1 Planned Performance Enhancements

- **GraphQL API:** Implement GraphQL alternative to REST API for more flexible queries
- **Real-time Updates:** WebSocket support for real-time notifications (new listings, reviews)
- **Caching Layer:** Redis caching for frequently accessed data (popular cars, reviews)
- **Content Delivery Network:** CDN integration for image and static asset delivery
- **API Response Optimization:** Implement pagination and lazy loading for large result sets

12.2 Planned Reliability Improvements

- **Multi-Region Deployment:** Replicate system across multiple geographic regions
- **Database Replication:** Implement master-slave replication for high availability
- **Circuit Breaker Pattern:** Implement circuit breakers for external service calls
- **Chaos Engineering:** Regular chaos testing to identify and fix reliability issues
- **SLA Guarantees:** Provide 99.99% uptime SLA with credits for non-compliance

12.3 Planned Security Enhancements

- **Two-Factor Authentication:** Implement 2FA using TOTP or SMS
- **OAuth2/OpenID Connect:** Support third-party authentication providers
- **Zero-Trust Architecture:** Move to zero-trust security model
- **Biometric Authentication:** Support biometric login on mobile platforms
- **Advanced Threat Detection:** Machine learning-based anomaly detection for security

12.4 Planned Scalability Improvements

- **Microservices Architecture:** Migrate from monolith to microservices
- **Event-Driven Architecture:** Implement event streaming (Kafka) for asynchronous processing
- **Sharding Strategy:** Implement database sharding for trillion-row scalability
- **Caching Strategy:** Multi-tier caching (L1: memory, L2: Redis, L3: database)
- **Global Load Balancing:** Geographic load balancing for global user distribution

12.5 Planned Feature Enhancements

- **Mobile App:** Native iOS and Android applications with offline capabilities
- **AI-Powered Search:** Machine learning for improved search and recommendations
- **Logistics Integration:** Partner with logistics providers for delivery
- **Trade-in Program:** Enable vehicle trade-in as payment method
- **Financing Options:** Partner with fintech for buy-now-pay-later options

13. Conclusion

This Non-Functional Requirements document establishes comprehensive quality standards, performance benchmarks, and operational constraints for the TrustLot platform. These requirements ensure that the system is not only functionally correct but also performant, reliable, secure, and maintainable.

Key Takeaways

1. **Performance First:** The system must deliver response times <2 seconds for 95% of user interactions
2. **Security Essential:** OWASP compliance and comprehensive encryption required for all data
3. **Reliability Paramount:** 99.5% uptime target with automatic failover and recovery mechanisms
4. **Scalability Inherent:** Stateless architecture enabling horizontal scaling to 10,000+ concurrent users
5. **Data Integrity Critical:** ACID compliance and comprehensive audit trails for all transactions

Implementation Timeline

Phase	Duration	Focus Areas
Phase 1 (Months 1-3)	3 months	Core NFRs: Performance, Security, Reliability
Phase 2 (Months 4-6)	3 months	Scaling, Monitoring, Advanced Logging
Phase 3 (Months 7-9)	3 months	Optimization, Load Testing, Compliance
Phase 4+	Ongoing	Future enhancements and improvements

Success Criteria

The system will be considered NFR-compliant upon achievement of: - Response time benchmarks met for 95%+ of requests - Zero critical security vulnerabilities in penetration tests - 99.5% uptime maintained over 30-day period - Ability to scale to 10,000 concurrent users with <10% degradation - Complete audit trail and logging for 100% of transactions

Review and Updates

This NFR document should be reviewed quarterly and updated annually to reflect: - Changes in technology landscape - New industry standards and compliance requirements - Lessons learned from production operations - Feedback from stakeholders and users - Emerging security threats and mitigation strategies
